REGULATORY FRAMEWORK

금융 AI 규제 준수 프레임워크

인공지능기본법 · EU AI Act · 금감원 AI RMF 대응
컴플라이언스 아키텍처 설계 문서

문서 분류	**기술 문서**
작성일	**2026년 4월**
버전	**v1.0**
관련 법령	**인공지능기본법 (법률 제20676호), EU AI Act, GDPR**

핵심 요약 — 본 문서는 금융 AI 추천 시스템(PLE 기반)이 준수해야 하는 국내외 규제 요건을 체계적으로 매핑하고, 각 요건에 대한 시스템 레벨 대응 아키텍처를 정의합니다.
한국 인공지능기본법(2026.1.22 시행), 금융위 통합 AI 가이드라인 7대 원칙, 금감원 AI RMF, EU AI Act(Art. 13/14/15), GDPR Art. 22를 대상으로 하며, 감사 추적 · 공정성 모니터링 · 드리프트 감시 · 쏠림 탐지 · 킬스위치 · 옵트아웃 · Human-in-the-Loop · 거버넌스 보고서 자동 생성까지 end-to-end 컴플라이언스 아키텍처를 포함합니다.

목차

금융 AI 규제 환경 개요 4
- 한국 인공지능기본법 4
- 금융위원회 통합 AI 가이드라인 7대 원칙 5
- 금감원 AI 위험관리 프레임워크 (AI RMF) 5
- EU AI Act와의 비교 5
- 글로벌 규제 흐름 요약 6

금감원 가이드라인 매핑 — 7대 원칙과 시스템 대응 7
- 원칙별 대응 매트릭스 7
- AI RMF 영역별 상세 매핑 7

EU AI Act 조항별 매핑 9
- Article 13: 투명성 및 정보 제공 9
- Article 14: 인간 감독 (Human Oversight) 9
- Article 15: 정확성, 견고성, 사이버보안 10
- GDPR Article 22: 자동화된 의사결정 10

한국 AI 기본법 고영향 AI 분류와 금융 적용 11
- 고영향 AI 해당 가능성 평가 11
- AI 기본법 주요 조항별 대응 현황 11
- 규제 타임라인 12

컴플라이언스 아키텍처 13
- 전체 구조 13
- 보안 통제 14
- 3계층 폴백 — 규제 보증으로서의 서비스 무중단 14
- 감사 추적 (Audit Trail) 15
- 공정성 모니터링 (Fairness) 16
- 드리프트 감시 (Drift) 16
- 쏠림 탐지 (Herding) 16
- 킬스위치 (Kill Switch) 17
- 옵트아웃 (Opt-out) 및 동의 관리 17
- 데이터 보존 정책 18
- 인시던트 관리 18
- Bedrock 데이터 보호 아키텍처 18

온프레미스 환경의 규제 준수 20
- 데이터 보호 20
- 모델 구성 20
- 운영/감사 에이전트 21
- 규제 충족 비교 21

Human-in-the-Loop 설계 22
- 설계 원칙 22
- 채널별 인간 감독 체계 22
- 5대 인간 개입 포인트 22

모델리스크관리 (MRM) 프레임워크 24
- MRM 생애주기 24

모델 인벤토리 25
독립적 검증 (Champion-Challenger) 25
지속적 모니터링과 재학습 트리거 25
비상 대응 (Kill Switch) 26
운영 및 감사 에이전트 27
아키텍처 개요 27
OpsAgent (운영 에이전트) 27
AuditAgent (감사 에이전트) 27
모델 선택 28
설계 원칙 28
Airflow DAG 통합 28
거버넌스 보고서 자동 생성 29
보고서 체계 29
36항목 규제 준수 자동 점검 29
거버넌스 3계층 체계 30
적용 규제 종합 매핑 30
운영/감사 에이전트 통합 31
시간적 팩트 스토어 (2026-04 추가) 31

금융 AI 규제 환경 개요

한국 인공지능기본법

2024년 12월 국회를 통과하고, 2025년 1월 21일 공포된 **「인공지능 발전과 신뢰 기반 조성 등에 관한 기본법」**(법률 제20676호)은 **2026년 1월 22일** 시행되었습니다. 아시아·태평양 지역 최초의 포괄적 AI 입법으로, 위험 기반 접근법(Risk-Based Approach)을 채택합니다.

법률 핵심 구조

투명성 의무 (제31조 / 시행령 제22조)
AI 사용 사실 사전 고지, AI 생성물 표시
위반 시 과태료 최대 3,000만 원

안전성 확보 (제32조 / 시행령 제23조)
학습 연산량 10^{26} FLOPs 이상 초거대 모델 대상
(추천 모델은 해당 없음 – **사용 영역** 기반 고영향 AI 분류 적용)

고영향 AI 확인 (제33조 / 시행령 제24조)
사업자의 자체 사전 검토 의무
필요시 과기정통부에 확인 요청 (30일 이내 회신)

고영향 AI 사업자 책무 (제34조 / 시행령 제26조)
위험 관리 방안 수립, 이용자 보호(설명가능성),
관련 사항 홈페이지 등에 공개

고영향 AI와 금융

인공지능기본법은 **"사람의 생명·신체의 안전, 기본권에 중대한 영향을 미치거나 위험을 초래할 수 있는 인공지능"**을 고영향 AI로 정의합니다(제2조 제4호). 시행령에서 11개 분야를 열거하며, **금융(신용·대출)** 분야가 명시적으로 포함됩니다.

분야	적용 예시	금융 관련성
의료	의료기기·디지털 의료기기에 활용되는 AI	간접
금융 (신용·대출)	**신용평가·대출심사 등 개인 권리관계 평가 AI**	**직접**
고용	채용·인사 의사결정 AI	없음
공공서비스	자격 확인, 행정 의사결정 AI	간접
원자력·생체정보	원자력 시설, 생체인식 분석 AI	간접

금융분야 시사점

대출심사·신용평가에 사용되는 AI는 법률상 명시적 고영향 AI에 해당합니다. 금융 AI 추천 시스템이 직접적인 여신 업무를 수행하지 않더라도, **상품 추천·적합성 판단·고객 분류** 등의 AI 활용이 향후 시행령 개정이나 금융위 가이드라인에 의해 고영향 AI로 확대 지정될 가능성이 존재합니다. 따라서 **고영향 AI에 준하는 수준**의 거버넌스 체계를 선제적으로 구축하는 것이 합리적 전략입니다.

금융위원회 통합 AI 가이드라인 7대 원칙

금융위원회는 인공지능기본법 시행에 맞추어 **「금융분야 AI 가이드라인 개정안」**을 발표했습니다. 업권별 자율규제·모범규준 형태로 **2026년 2분기 시행** 예정이며, 7대 원칙을 중심으로 구성됩니다.

1. 거버넌스

최고경영자 포함 경영진의 역할·책임 분담
AI 위험관리 조직을 기획·개발과 **독립 분리**

2. 합법성

AI기본법, 개인정보보호법, 신용정보법 준수

3. 보조수단성

AI는 의사결정 보조 수단,
외부 모델 활용 시에도 최종 책임은 금융회사

4. 신뢰성

모델 성능·편향성 관리, 설명가능성(XAI) 확보

5. 금융안정성

제3자 의존성, 시장 동조화 리스크 평가
사고 시 금융당국 보고

6. 신의성실

모든대고객 AI 서비스 사전고지(AI기본법보다넓음)
이해상충 방지, 공정성 기준 설정·평가

7. 보안성

데이터 오염·모델 오염·프롬프트 인젝션 등
AI 특화 위협 대응 체계 구축

출처: 금융위원회 보도자료 (2025.12)

금감원 AI 위험관리 프레임워크 (AI RMF)

금융감독원은 2026년 1월 **「금융분야 AI 위험관리 프레임워크(AI RMF)」**를 도입했습니다. 현재 **118개 금융회사가 653개 AI 서비스**를 운영 중이나, 약 **85%가 AI 윤리원칙과 위험관리 기준 미비** 상태입니다.

AI RMF 3대 영역

1. 거버넌스
AI 의사결정기구·전담조직 설치
위험관리규정 수립
기획·개발 조직과 **독립 분리**

2. 위험평가
위험 인식·측정 → 경감
→ 잔여위험
고·중·저 3단계 등급 분류
합법성·신뢰성·신의성실·보안성 정량 평가

3. 위험통제
출시 전 위험경감 조치 검증
운영단계별 모니터링 기준
위험 변경 시 등급 재평가

EU AI Act와의 비교

구분	한국 인공지능기본법	EU AI Act
시행일	2026. 1. 22.	고위험 AI: 2027. 12.
분류 체계	일반/고영향 (2단계)	금지/고위험/제한/최소 (4단계)
금융 적용	신용평가·대출심사 명시	신용평가·보험 산정 포함
금지 AI	없음	사회점수 부여, 실시간 원격 생체인식 등
의무 대상	사업자 중심 단일 기준	공급자·배포자·이용자 등 공급망 전체

제재 수준	과태료 최대 3,000만 원	글로벌 매출 최대 7% 또는 3,500만 유로
접근 방식	진흥 중심 + 자율규제	안전 중심 + 강제적 준수
영향평가	노력 의무	사전 적합성 평가 법적 의무

비교의 시사점

한국의 AI 기본법은 EU 대비 제재 수준이 **수천 배 낮고** 자율규제 비중이 크지만, 이는 **시행 초기 연착륙 전략**입니다. 금융위 통합 가이드라인은 AI 기본법보다 적용 범위가 넓어 **모든 대고객 AI 서비스에 사전 고지**를 요구합니다. 향후 시행령 개정과 금융위 세부 규율을 통해 규제 강도가 점진적으로 높아질 것으로 예상되며, **선제적 대비**가 유리합니다.

글로벌 규제 흐름 요약

금융 AI에 대한 글로벌 규제는 세 가지 방향으로 수렴하고 있습니다.

투명성·설명가능성

AI 사용 고지 의무 확대
의사결정 근거 설명 요구
자동화 의사결정 거부권 보장

공정성·비차별

보호 속성별 편향 정량 측정
시장 쏠림·이해상충 방지
정기적 공정성 감사 의무화

안전성·책임성

위험 기반 분류(고위험 AI)
긴급 중단 메커니즘 의무
감사 추적 및 보존 의무

금감원 가이드라인 매핑 — 7대 원칙과 시스템 대응

금융위 통합 AI 가이드라인 7대 원칙 및 금감원 AI RMF 요구항목에 대해, PLE 기반 금융 AI 추천 시스템의 대응 현황을 매핑합니다.

원칙별 대응 매트릭스

7대 원칙	시스템 대응	수준
1. 거버넌스 (AI RMF G-1~G-6)	3계층 거버넌스 프레임워크 설계 완료 (의사결정 위원회 → 운영팀 → 내부 감사) 월/분기 거버넌스 보고서 자동 생성 36항목 규제 준수 레지스트리 자동 점검	○
2. 합법성 (AI RMF R-2)	적격성·적정성 자동 검증 (금소법 §17·18) 개인정보 비식별화 (SHA-256 + 도메인별 Salt) 신용정보법 보관 의무 준수 (5년)	●
3. 보조수단성 (AI RMF C-4)	인간 감독 + Kill Switch 3단계 긴급 차단 인적 재처리 라우팅 (P1/P2/P3 SLA) AI 자동화 의사결정 거부권 + 대체 경로	●
4. 신뢰성 (AI RMF R-3, C-2~C-3)	Champion-Challenger 자동 모델 경쟁 PSI 기반 드리프트 감지 + 3일 연속 재학습 트리거 LGBM SHAP 기반 피처별 기여도 + 자연어 추천 사유 생성	●
5. 금융안정성 (AI RMF R-3~R-4)	HHI·Gini·Entropy 쏠림 탐지 DI·SPD·EOD 공정성 3대 지표 자동 측정 보호 속성 5개 (연령·성별·지역·소득·생애주기)	●
6. 신의성실 (AI RMF R-4)	AI 사용 고지 중앙 관리 + 세그먼트별 안내 분리 이해상충 방지 (고수수료 상품 40% 초과 시 자동 페널티) 옵트아웃 등록·철회·확인 전 생애주기 관리	●
7. 보안성 (AI RMF R-5)	프롬프트 인젝션 방어 8패턴 (한국어 4 + 영어 4) 모델 무결성 SHA-256 해시 검증 HMAC + 해시 체인 감사 로그 불변성	●

● 충족 ○ 부분 충족 (조직 의사결정 필요)

AI RMF 영역별 상세 매핑

영역 1: 거버넌스 (G-1 G-6)

No.	RMF 요구항목	현재 대응 현황	수준
G-1	AI 최고 의사결정기구 설치	3계층 거버넌스 프레임워크 설계, 위원회 공식 설치 필요	△
G-2	AI 위험관리 전담조직 (독립)	운영팀 개발·운영 겸임, 독립 기능 분리 필요	△

G-3	AI 위험관리규정 수립	FD-TVS·드리프트 감지 등 로직 존재, 내규 문서화 필요	○
G-4	AI 윤리원칙 수립·공표	미수립 – 전사 AI 윤리원칙 문서화 필요	△
G-5	고영향 AI 사전 승인 절차	서비스 출시 전 승인 프로세스 공식화 필요	△
G-6	AI 활용 현황 정기 보고	월간 리포트 자동 생성 완비, 보고 라인 공식화 필요	○

영역 2: 위험평가 (R-1 R-6)

No.	RMF 요구항목	현재 대응 현황	수준
R-1	AI 서비스별 위험등급 분류	고영향 AI 해당 가능성 자체 평가 완료, 공식 분류 체계 필요	○
R-2	합법성 평가	적격성 자동 검증 + 비식별화 + 보관 의무 준수	●
R-3	신뢰성 평가	Champion-Challenger + 드리프트 감지 + 공정성 자동 측정	●
R-4	신의성실 평가	보호 속성 5종 DI·SPD·EOD + 이해상충 방지 + Parquet 아카이빙	●
R-5	보안성 평가	로컬 AI + SHA-256 암호화 + 프롬프트 인젝션 방어 + 무결성 검증	●
R-6	잔여위험 평가	FD-TVS 리스크 페널티 자동 차단, Risk Appetite 문서화 필요	○

영역 3: 위험통제 (C-1 C-6)

No.	RMF 요구항목	현재 대응 현황	수준
C-1	출시 전 위험경감 조치 검증	적격성 규칙 + 피로도 필터링 + A/B 테스트 체계	●
C-2	운영 모니터링 기준	드리프트 자동 감지 + 성과 대시보드 + 이상 알림	●
C-3	모델 성능 정기 평가·재학습	주간/월간 자동 재학습 + Champion-Challenger + MLflow 버전 관리	●
C-4	인간 감독 체계	Kill Switch 3단계 + 인적 재처리 라우팅 + 옵트아웃	●
C-5	긴급 중단 메커니즘	GLOBAL/PER_TASK/PER_CLUSTER 3단계 킬스위치	●
C-6	감사 추적 확보	HMAC 해시 체인 + S3 Object Lock + 7개 감사 테이블	●

EU AI Act 조항별 매핑

EU AI Act는 금융 AI 추천 시스템을 **고위험 AI**(Annex III, 5(b): 신용평가·보험 산정)로 분류할 가능성이 높습니다. 주요 조항별 시스템 대응을 매핑합니다.

Article 13: 투명성 및 정보 제공

Art. 13 요구사항과 시스템 대응

Art. 13 요구사항	시스템 대응
고위험 AI 사용 사실 고지	AI 사용 고지 중앙 관리 + 세그먼트별 안내 분리 모든 추천 출력에 AI 사용 표기 자동 포함
시스템 작동 방식 설명	2-Layer 추천 사유 생성 (L1 Template + L2 LLM) 3-Agent 파이프라인 (Feature Selector → Reason Generator → Safety Gate)
입력 데이터 사양 공개	피처 스키마 자동 문서화 (349D 입력 / 403D Phase 0 후 현재 구현 / 734D 풀뱅크 설계) 학습 데이터 출처·범위·가명처리 여부 기록
성능 수준 공개	모델 카드 자동 생성 (아키텍처·성능·피처 중요도) 태스크별 독립 AUC 추적 (13개 태스크)
로그 생성 의무	HMAC + 해시 체인 감사 로그 (S3 Object Lock WORM) 추천 이력 전수 Parquet 아카이빙

Article 14: 인간 감독 (Human Oversight)

Art. 14 요구사항과 시스템 대응

Art. 14 요구사항	시스템 대응
인간이 AI 시스템을 감독할 수 있는 인터페이스 제공	오프라인: 직원 화면에 추천 리스트 + 사유 제공, 최종 권유는 직원 판단 온라인: AI 운영팀이 추천 방향·대상·제외 목록 직접 제어
시스템 작동을 개입·중단할 수 있는 능력 보장	Kill Switch 3단계 (GLOBAL/PER_TASK/PER_CLUSTER) 드리프트 감지 시 보수적 모드 자동 전환
자동화 결정에 대한 거부·대안 경로	옵트아웃 등록·철회·확인 + 인적 재처리 3단계 라우팅 (P1 긴급 1h / P2 4h / P3 24h SLA)

Article 15: 정확성, 견고성, 사이버보안

Art. 15 요구사항과 시스템 대응

Art. 15 요구사항	시스템 대응
적절한 정확성 수준 달성 및 유지	Champion-Challenger 자동 모델 경쟁 PSI 기반 드리프트 감지 + 3일 연속 임계 초과 시 자동 재학습
오류·결함에 대한 견고성	Ablation 기반 컴포넌트별 기여도 정량 검증 증류 LGBM 폴백 (teacher 성능 이상 시 자동 전환)
사이버보안 위협 대응	프롬프트 인젝션 방어 8패턴 (심각도 5단계) 모델 무결성 SHA-256 검증 입력 검증 (포맷 + 크기 제한)
편향 방지 조치	DI·SPD·EOD 3대 공정성 지표 자동 측정 보호 속성 5종 상시 감시 임계값 위반 시 자동 인시던트 생성

GDPR Article 22: 자동화된 의사결정

GDPR Art. 22 및 관련 조항 대응

GDPR Art. 22는 정보주체에게 **"프로파일링을 포함한 자동화된 의사결정에만 기반한 결정"**에 대한 거부권을 부여합니다. 한국 개인정보보호법 §37조의2도 동일한 권리를 보장합니다.

GDPR 요구사항	시스템 대응
자동화 의사결정 거부권 (Art. 22(1))	옵트아웃 등록·철회·확인 전 생애주기 관리 거부 시 즉시 인적 대체 경로 전환
인적 개입 요청권 (Art. 22(3))	인적 재처리 라우팅 (7개 사유별 자동 상담원 전환) P1/P2/P3 SLA 관리
프로파일링 관련 정보 제공 (Art. 13(2)(f))	의사결정 기준 자동 문서화 (30개+ 필터 사유 한국어 설명) 피처 역매핑 + 태스크별 해석
삭제권 (Art. 17)	30일 PII 보존 정책 + 암호화 삭제 S3 Lifecycle 자동 적용
정보주체 권리 행사 감사 (Art. 30)	7개 감사 테이블 중 profiling_audit, opt_out_audit, consent_audit DynamoDB 서버리스 관리 + TTL 자동 정리

한국 AI 기본법 고영향 AI 분류와 금융 적용

고영향 AI 해당 가능성 평가

현행법상 금융상품 추천 시스템은 **대출심사에 해당하지 않으므로** 명시적 고영향 AI 분류 대상은 아닙니다. 그러나 다음 시나리오에서 확대 지정 가능성이 존재합니다.

시나리오	가능성	근거
시행령 개정으로 금융상품 추천 전반 포함	중간	EU AI Act가 이미 이 범위 포함
고객 분류·세그먼트가 권리관계 평가로 해석	낮음 중간	투자 적합성 판단과 유사 구조
보험 상품 추천으로 업무 확대 시	높음	보험 산정은 EU 고위험·국내 고영향 모두 해당
이탈 예측 기반 차별적 혜택 제공	중간	공정성 이슈와 직결
금융위 가이드라인에서 추천 AI 별도 규율	중간 높음	통합 가이드라인 시행 후 추이 관찰 필요

> **대응 전략**
>
> 현시점에서 직접적 고영향 AI 해당은 아니나, **규제 환경의 방향성**을 고려하면 사실상 **고영향 AI에 준하는 수준**의 거버넌스 체계를 미리 구축하는 것이 합리적 전략입니다. 이는 규제 리스크 최소화뿐 아니라, 향후 업무 확대(보험·펀드 추천 등) 시 즉시 대응 가능한 기반이 됩니다.

AI 기본법 주요 조항별 대응 현황

요구사항	근거	현재 대응	수준
AI 사용 사실의 사전 고지	제31조	AI 사용 고지 중앙 관리, 세그먼트별 안내 분리 모든 추천 출력에 자동 포함	●
AI 생성물의 표시	제31조	추천 사유 텍스트에 AI 생성 표기 자동 적용	●
위험 관리 조치 이행	제32조	FD-TVS + Kill Switch(3단계) + 적격성·적정성 검증 1. 드리프트 감지	●
고영향 AI 해당 여부 확인	제33조	시나리오별 해당 가능성 분석 완료	●
위험 관리 방안·이용자 보호	제34조	안전신뢰문서 + 모델카드 자동 생성 추천 사유 3단계 파이프라인	●
영향평가 실시	제35조	시스템 문서화 완비, 정기 실시 프로세스 조직 수립 필요	○
자동화 의사결정 거부권	개보법 §37조의2	옵트아웃 + 인적 재처리 3단계 라우팅	●
거버넌스 체계 구축	7대 원칙	3계층 프레임워크 설계, 위원회 공식 설치 필요	○

● 충족 ○ 부분 충족 △ 미비

규제 타임라인

주요 규제 일정

일자	이벤트
2025. 1. 21	AI 기본법 공포
2025. 08	AI 기본법 시행령 입법예고
2025. 12. 22	금융위 통합 AI 가이드라인(안) 공개
2026. 1. 15	금감원 AI RMF 도입
2026. 01. 22	**AI 기본법 시행**
2026 Q1	통합 가이드라인 및 AI RMF 확정·시행
2027. 01 (예상)	AI 기본법 과태료 실제 부과 시작
2027. 12	EU AI Act 고위험 AI 규정 완전 적용

컴플라이언스 아키텍처

전체 구조

규제 준수 인프라를 3개 레이어로 구성합니다.

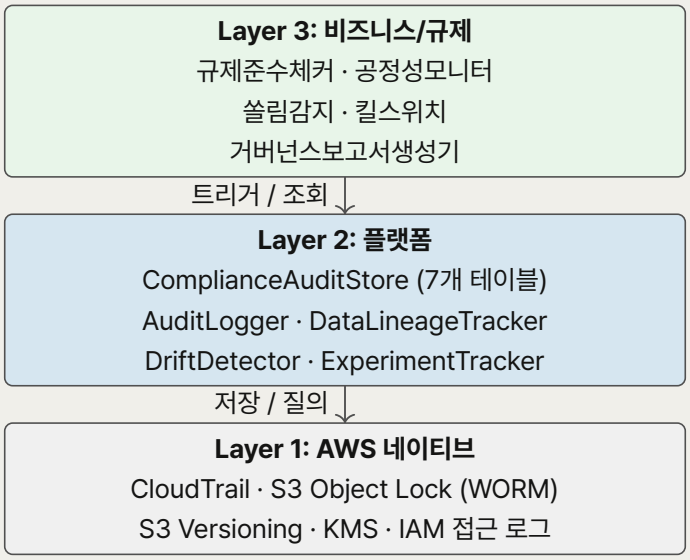

그림 1: 3계층 컴플라이언스 아키텍처.

Layer 1: AWS 네이티브 (자동, 추가 비용 없음)

- **CloudTrail** → 모든 AWS API 호출 자동 기록
- **S3 Versioning** → 데이터/모델 변경 이력 보존
- **S3 Object Lock** → 감사 로그 불변성 (WORM)
- **KMS** → 암호화 키 관리 + 키 사용 감사
- **IAM Access Log** → 리소스 접근 감사

Layer 2: 플랫폼 레벨 (반자동)

- **ComplianceAuditStore** → 7개 감사 테이블 (DynamoDB)
- **AuditLogger** → HMAC + 해시 체인 (S3 + DynamoDB)
- **DataLineageTracker** → 피처→원천 추적 (S3 메타데이터)
- **ExperimentTracker** → 실험 메트릭 (SageMaker Experiments)
- **DriftDetector** → PSI 모니터링 (SageMaker Model Monitor)

Layer 3: 비즈니스/규제 레벨 (명시적)

- **RegulatoryComplianceChecker** → 36항목 자동 점검
- **FairnessMonitor** → DI/SPD/EOD 보호 속성 감시 (주기별 배치 평가)

- **HerdingDetector** → 시스템 리스크 쏠림 탐지
- **IncidentReporter** → 심각도별 자동 보고
- **GovernanceReportGenerator** → 월/분기 거버넌스 보고서 (주기별 자동 생성)
- **KillSwitch** → 긴급 모델 비활성화
- **ComplianceAuditStore** → 모든 예측 건에 전체 컴플라이언스 컨텍스트 로그
- **ConsentManager** → 마케팅 동의 생애주기 (부여/철회/갱신/확인)
- **AIOptOut** → AI 결정 거부 등록·철회·확인
- **ProfilingRights** → 정보주체 권리 행사 (열람/정정/삭제/이동)

보안 통제

PII 보호 및 LLM 보안

서빙 시 PII 마스킹: 고객 개인정보(성명, 계좌번호, 주민등록번호)는 추천 사유 생성 파이프라인 진입 전에 마스킹 처리됩니다. LLM 레이어에는 익명화 토큰만 전달되어, 외부 모델 제공사로의 PII 유출을 구조적으로 차단합니다.

LLM 호출의 PromptSanitizer: Bedrock(Claude Haiku)에 전달되는 모든 프롬프트는 `PromptSanitizer`를 통해 전처리됩니다. 8가지 인젝션 패턴(한국어 4 + 영어 4)을 제거하고 프롬프트 구조를 검증한 후 API를 호출합니다. 금융위 7대 원칙 7번(보안성)과 AI 기본법 제34조(위험관리)를 충족합니다.

구조적 분리: 컴플라이언스 모듈(ConsentManager, AIOptOut, RegulatoryChecker, ProfilingRights)은 스코어링 및 사유 생성 경로와 독립적으로 동작합니다. 컴플라이언스 검사는 사전 게이트로 강제되며, 모든 조건이 충족될 때만 예측 결과가 서빙됩니다.

3계층 폴백 — 규제 보증으로서의 서비스 무중단

3계층 폴백 아키텍처는 서비스가 완전히 멈추지 않도록 보장합니다. 이는 금감원 AI RMF C-5(비상 중단 및 폴백)의 핵심 규제 요구사항입니다.

계층	메커니즘	활성 조건
1계층 (Primary)	Lambda + FallbackRouter를 통한 증류 LGBM Student	정상 운영
2계층 (Failover)	PLE Teacher 직접 추론 (SageMaker Endpoint)	Student 성능 저하 또는 이용 불가
3계층 (Safety Net)	규칙 기반 엔진: 13개 태스크 규칙 + Financial DNA 라우팅	두 모델 계층 모두 이용 불가

규제적 의미: CRITICAL 킬스위치 발동 시에도 3계층이 규칙 기반 상품 안내를 보장하여 서비스 완전 차단을 방지합니다. 세 계층 모두 설명 컴플라이언스를 위한 `contributing_features`를 생성합니다.

CloudFormation DynamoDB 컴플라이언스 테이블

다음 DynamoDB 테이블이 컴플라이언스 상태 관리를 위해 CloudFormation으로 프로비저닝됩니다:

> - `consent-store`: 마케팅 동의 기록 (부여/철회/갱신/채널)
> - `opt-out-store`: 고객별 AI 결정 거부 이력
> - `profiling-rights-store`: 정보주체 권리 행사 기록
> - `audit-store`: 예측 건별 컴플라이언스 감사 로그 (ComplianceAuditStore)
>
> 모든 테이블은 7년 보존 정책에 맞춰 TTL 자동 정리를 적용합니다.

감사 추적 (Audit Trail)

불변 로그 — HMAC + 해시 체인

각 감사 로그 엔트리에 HMAC-SHA256 서명을 부여하고, 연속 엔트리 간 SHA256 해시 체인(prev_hash)으로 연결하여 위변조를 방지합니다.

On-Prem	AWS
로컬 JSONL + HMAC + 해시 체인	S3 Object Lock (WORM) + HMAC + 해시 체인

AWS 강화 요소:
- S3 Object Lock: AWS 레벨에서 물리적 삭제 차단 (관리자도 삭제 불가)
- KMS 암호화: 감사 로그 자체를 암호화
- CloudTrail: 감사 로그에 대한 접근도 감사 (메타 감사)

7개 규제 감사 테이블

DynamoDB 기반 서버리스 관리 (자동 스케일링, 항목별 TTL):

테이블	용도	보존 기간
ks_audit	킬스위치 활성화/비활성화 이력	7년
consent_audit	마케팅 동의 변경 이력 (부여/철회/갱신)	7년
profiling_audit	정보주체 권리 행사 (열람/정정/삭제/제한/이동)	7년
opt_out_audit	AI 결정 거부 이력	7년
incident_audit	규제 인시던트 (심각도별)	7년
distillation_audit	교사-학생 모델 성능 갭	3년
embedding_audit	임베딩 품질 메트릭	3년

공정성 모니터링 (Fairness)

보호 속성 5개에 대해 3대 공정성 지표를 상시 감시합니다.

소득 관련 주의사항: **소득(income)**은 입력 피처이자 공정성 편향 모니터링 대상 보호 속성이다. 모델 태스크가 아니다. 결정론적 버킷 변환인 `income_tier`는 리키지 이유로 태스크에서 제거되었다(v14 태스크 세트) — 모델이 피처에서 레이블을 완벽히 복원할 수 있기 때문이다. 소득 피처 자체는 유지되며 공정성 모니터링 대상이다.

보호 속성

- **연령대**: youth / middle / pre_senior / senior
- **성별**: M / F / unspecified
- **지역 유형**: metropolitan / urban / rural
- **소득 분위**: low / middle / high (피처, 태스크 아님)
- **생애주기**: 6개 클래스

임계값 및 조치

- **DI (Disparate Impact)**: 0.8 1.25
- **SPD (Statistical Parity Difference)**: |SPD| ≤ 0.1
- **EOD (Equal Opportunity Difference)**: |EOD| ≤ 0.1

DI < 0.6 → CRITICAL 인시던트
DI < 0.8 → MAJOR 인시던트
|SPD| > 0.1 → MINOR 인시던트

드리프트 감시 (Drift)

SageMaker Model Monitor (기본) + 커스텀 PSI (확장)를 결합합니다.

지표	임계값	자동 조치
PSI (warning)	0.1	경고 로깅
PSI (critical)	0.25	담당자 알림
연속 3일 critical	–	자동 재학습 트리거 (Step Functions)

피처별 개별 PSI를 추적하여, 전체 분포가 안정적이더라도 특정 피처의 급변을 조기에 감지합니다.

쏠림 탐지 (Herding)

동일 상품에 추천이 과도하게 집중되는 **시스템 리스크**를 방지합니다.

지표	설명	심각도 분류
HHI	허핀달-허쉬만 지수 – 시장 집중도	none → low → medium
Gini 계수	추천 불평등 측정	→ high → critical
Entropy	추천 다양성 측정	
쏠림률	최다 추천 상품의 비율	critical 시 킬스위치 검토

킬스위치 (Kill Switch)

3단계 긴급 모델 비활성화 체계입니다.

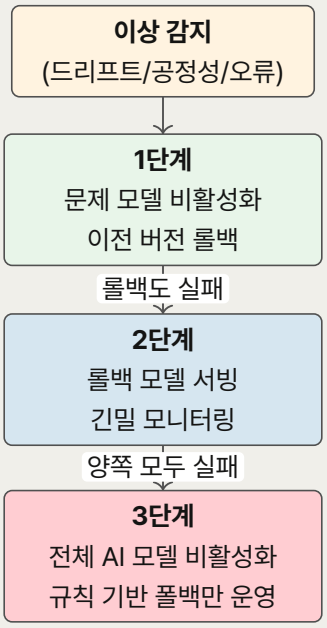

그림 2: 킬스위치 에스컬레이션: 3단계 캐스케이드. 서비스가 완전히 중단되지 않음.

킬스위치 구조

GLOBAL
전체 모델 비활성화
DynamoDB 상태 저장
매 요청마다 확인

PER_TASK
특정 태스크만 비활성화
(예: click, purchase)
해당 태스크만 폴백

PER_CLUSTER
특정 고객군만 비활성화
(예: cluster_5)
해당 클러스터만 폴백

폴백 전략: 규칙 기반 추천 / 이전 모델 롤백 / 추천 비활성화 중 선택

옵트아웃 (Opt-out) 및 동의 관리

기능	설명
AI 결정 거부 등록	옵트아웃 등록 → 즉시 인적 대체 경로 전환
거부 철회	이전 옵트아웃 철회 → AI 추천 재활성화
마케팅 동의 관리	부여/철회/갱신 이력 추적, 채널별·목적별 옵트인 확인
야간 SMS 차단	마케팅 동의 여부 + 시간대 자동 필터링
감사 추적	모든 동의 변경·거부 이력을 consent_audit, opt_out_audit에 기록

데이터 보존 정책

S3 Lifecycle Rule으로 자동 적용합니다.

카테고리	보존 기간	조치	규제 근거
Raw Data	30일	삭제	GDPR 최소화 원칙
Processed Features	90일	Glacier 아카이브	재학습 지원
Training Data	365일	Glacier 아카이브	재현성 보장
Model Checkpoints	365일	보관	롤백 지원
Inference Results	90일	삭제	분쟁 대응
Audit Logs	2,555일 (7년)	불변 보관 (WORM)	금융 규제 7년 보존
PII Data	30일	암호화 삭제	GDPR §17 삭제권

인시던트 관리

심각도별 자동 분류 및 대응 체계입니다.

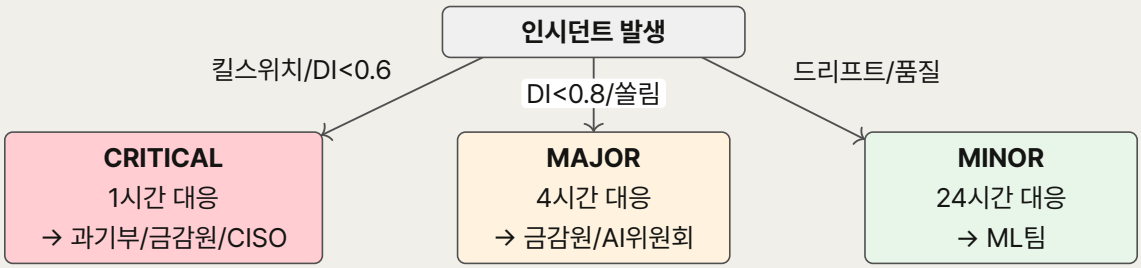

그림 3: 인시던트 심각도 분류 및 에스컬레이션.

심각도	대응 시간	트리거	보고 대상
CRITICAL	1시간	킬스위치 발동, DI<0.6, 보안 침해	과기부/금감원/CISO
MAJOR	4시간	DI<0.8, 쏠림 critical, 모델 롤백	금감원/AI 위원회
MINOR	24시간	드리프트 경고, 품질 저하, 쏠림 high	ML팀

Bedrock 데이터 보호 아키텍처

금융 AI 시스템에서 LLM을 활용할 때 가장 중요한 규제 이슈는 고객 데이터의 외부 유출이다. Amazon Bedrock은 다음 5가지 구조적 보호 장치를 통해 이 문제를 해결한다:

보호 장치	상세
데이터 미학습	입출력 데이터가 모델 제공사(Anthropic, Meta 등)에 전달되지 않으며, 모델 재학습(fine-tuning 포함)에 사용되지 않는다. AWS가 이를 서비스 약관으로 보장한다.
전송 암호화	TLS 1.2+ 암호화로 전송 중 데이터를 보호한다.
VPC PrivateLink	인터넷을 경유하지 않고 VPC 내부 엔드포인트를 통해 Bedrock API를 호출한다. 고객 데이터가 공개 네트워크에 노출되지 않는다.

리전 내 처리	모든 추론이 ap-northeast-2(서울) 리전에서 처리된다. 고객 데이터가 한국 밖으로 전송되지 않는다.
CloudTrail 감사	모든 Bedrock API 호출(InvokeModel, Converse 등)이 CloudTrail에 자동 기록된다. 누가 언제 어떤 모델을 호출했는지 완전한 감사 추적이 가능하다.

규제 매핑

규제	요구사항	Bedrock 충족 방식
개인정보보호법	제3자 제공 vs 위탁 처리 구분	Bedrock은 AWS 인프라 내 위탁 처리에 해당. 데이터가 모델 제공사에 전달되지 않으므로 제3자 제공이 아님.
개인정보보호법	국외 이전 제한	ap-northeast-2 리전 내 처리. 국외 이전 불발생.
금감원 AI 가이드라인	데이터 거버넌스	CloudTrail 감사 로그 + VPC 격리 + 전송 암호화로 데이터 흐름 완전 추적.
EU AI Act Art.10	데이터 거버넌스	학습 데이터 미사용 보장. 추론 데이터 처리 위치 문서화.
AI 기본법	고영향 AI 데이터 관리	HMAC 감사 로그와 CloudTrail 이중 기록으로 데이터 처리 이력 증명.

데이터 흐름도

추천사유 생성 및 에이전트 진단 시 데이터 흐름:

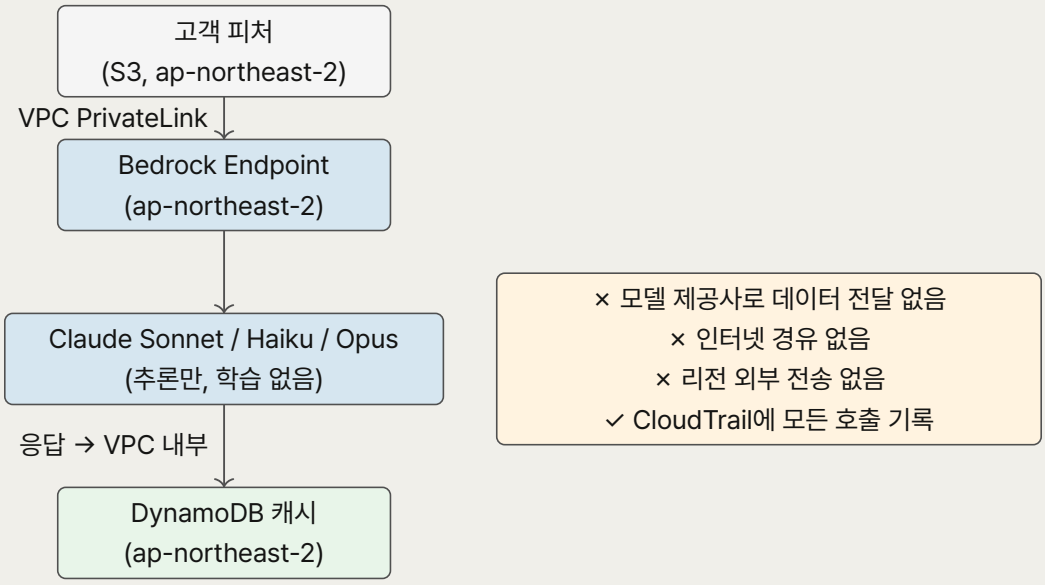

그림 4: AWS Bedrock 데이터 흐름: VPC PrivateLink로 리전 외부 전송 없이 처리.

온프레미스 환경의 규제 준수

폐쇄망(air-gapped) 온프레미스 환경은 외부 네트워크 접근이 원천적으로 차단되어, 데이터 보호 관점에서 AWS보다 **구조적으로 더 강력**하다.

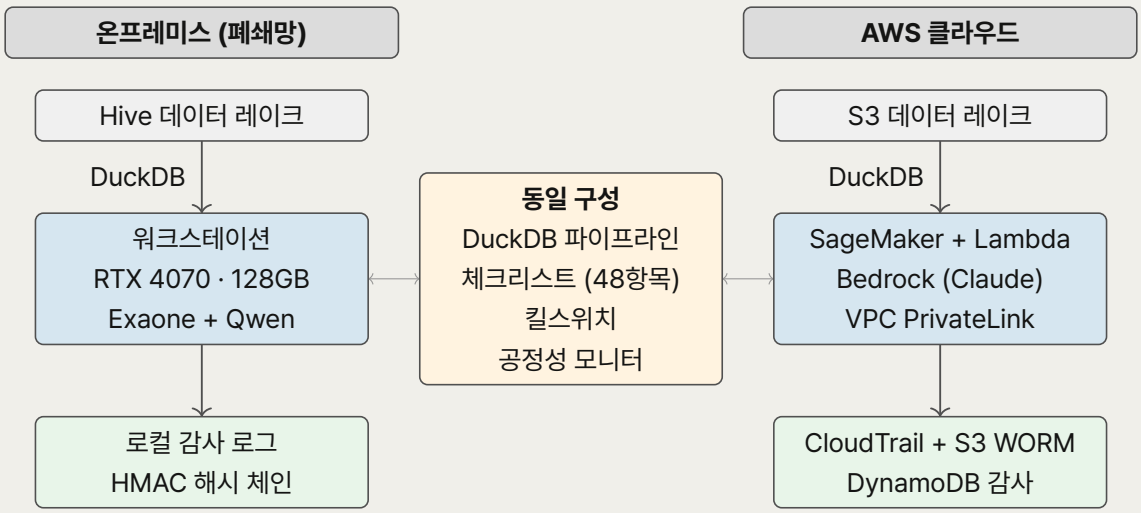

그림 5: 온프레미스 vs AWS: 동일한 DuckDB 파이프라인과 규제 준수 프레임워크, 인프라 계층만 다름.

데이터 보호

항목	온프레미스	AWS (Bedrock)
외부 데이터 전송	**원천 불가** — 폐쇄망	VPC PrivateLink로 리전 내 처리
모델 제공사 데이터 접근	**해당 없음** — 로컬 오픈소스 모델	Bedrock 약관으로 미전달 보장
감사 추적	로컬 HMAC 해시체인 (JSONL)	S3 Object Lock + CloudTrail
국외 이전	**발생 불가**	ap-northeast-2 내 처리

모델 구성

온프레미스에서 사용하는 모델은 모두 오픈소스이다:

용도	모델	라이선스 및 비고
추천사유 생성/critique	Exaone 3.5 7.8B	Apache 2.0 (LG AI Research). 한국어 특화.
에이전트 합의	Qwen 2.5 14B Q4	Apache 2.0 (Alibaba). 논리적 추론 특화.
임베딩	all-MiniLM-L6-v2	Apache 2.0 (sentence-transformers).

RTX 4070 (12GB VRAM)에서 순차 로딩으로 운용한다. 벤더 종속성이 없으며, 모델 교체가 config 변경만으로 가능하다.

운영/감사 에이전트

온프레미스 에이전트는 AWS와 **동일한 룰 엔진 + 체크리스트 + 도구 카탈로그**를 사용한다. 차이점:

기능	온프레미스	AWS
체크리스트 자동 판정	동일 (48항목)	동일
합의 메커니즘	2-Round 하이브리드 (Qwen 14B × 5+2)	독립 투표 (Sonnet × 3)
마이너리티 리포트	동일 — Round 1에서 확정, 삭제 불가	동일
담당자 대화	미제공 — 정형 리포트만	Sonnet Tool Use 대화
케이스 스토어	동일 (LanceDB)	동일
알림	이메일/Slack	SNS + Slack

규제 충족 비교

규제 요구사항	온프레미스 충족	AWS 충족
개인정보보호법 국외이전	원천 불가 (폐쇄망)	ap-northeast-2 내 처리
금감원 데이터 거버넌스	로컬 HMAC 감사 로그	CloudTrail + S3 Object Lock
EU AI Act 인간 감독	에이전트 권고 + 담당자 판단 (동일)	동일 + 대화 인터페이스
AI 기본법 킬스위치	로컬 킬스위치 (동일)	DynamoDB 킬스위치
설명 가능성	LGBM SHAP 기반 사유 + Exaone 리라이트	LGBM SHAP 기반 사유 + Claude Sonnet 리라이트

온프레미스는 대화형 에이전트가 없는 대신, 데이터 보호가 구조적으로 완벽하다. 규제기관 관점에서 "고객 데이터가 절대 외부로 나가지 않는다"는 가장 강력한 보호 근거이다.

Human-in-the-Loop 설계

금감원은 최종적으로 **사람의 개입에 따른 의사결정**을 요구합니다. EU AI Act Art. 14도 동일한 원칙을 명시합니다. 모든 것이 자동화되어 있더라도, 최종 검수는 사람이 수행합니다.

설계 원칙

> **AI는 도구이고, 최종 결정권은 사람에게**
>
> PLE 기반 추천 시스템은 "사람을 대체"하는 것이 아니라 "사람의 의사결정을 지원"하는 도구입니다. 이 원칙은 시스템 아키텍처 전반에 내장되어 있습니다.

채널별 인간 감독 체계

채널	인간 감독 방식
오프라인 (창구)	AI가 직원 화면에 추천 리스트 + 사유를 **제공** 최종 권유 여부는 **직원이 판단** 추천 사유를 확인한 뒤 고객 상황에 맞게 권유
온라인 (앱/웹)	AI가 추천 리스트를 자동 서빙 AI 운영팀이 추천 방향·대상·제외 목록을 **직접 제어** 긴급 시 킬스위치로 즉시 차단

5대 인간 개입 포인트

1. 추천 사유 샘플링 검수

전수 조사는 불가하더라도, 주기적으로 추천 사유 생성 결과를 샘플링하여 품질·적합성·규제 준수 여부를 검수합니다. 추천 품질 모니터링 시스템(L1 규칙 / L2a 리라이트 / L2b LLM 검증)이 자동 품질 지표를 산출하고, 이상 징후 발견 시 인간 검토를 트리거합니다.

2. 모델 교체 승인

Champion-Challenger 비교 결과를 사람이 확인한 후 승인합니다. 자동 교체 시에도 교체 사유·성능 비교·공정성 지표를 포함한 리포트가 생성되며, 운영팀이 사후 검토합니다.

3. 인시던트 에스컬레이션

자동 탐지된 이상 징후(공정성 위반, 드리프트, 쏠림)를 사람이 판단하여 조치합니다. CRITICAL 인시던트는 킬스위치 자동 발동 후 사람이 원인 분석 및 복구를 수행합니다.

4. 공정성 리뷰

공정성 모니터링 결과를 주기적으로 사람이 리뷰합니다. DI·SPD·EOD 자동 측정 결과에 대해 도메인 전문가가 맥락을 고려한 해석을 제공하고, 필요시 임계값 조정이나 모델 재학습을 결정합니다.

5. 옵트아웃·이의 제기 처리

고객의 AI 결정 거부 및 이의 제기에 대해 인적 재처리 경로가 자동으로 활성화됩니다. 7개 사유별 자동 상담원 전환이 이루어지며, P1(1h)/P2(4h)/P3(24h) SLA로 관리됩니다.

인적 재처리 사유 분류

P1 (긴급 1시간)
- 컴플라이언스 위반 탐지
- 적합성 미달 고객
- 킬스위치 발동 상황

P2 (4시간) / P3 (24시간)
- AI 결정 거부(옵트아웃)
- 저신뢰 추천 결과
- 설명 보충 요청
- 일반 이의 제기

모델리스크관리 (MRM) 프레임워크

미국 연준/OCC의 **SR 11-7**(모델 리스크 관리 가이던스), **NIST AI RMF 1.0**, 그리고 **EBA 머신러닝 가이드라인**은 모델의 전 생애주기에 걸친 체계적 리스크 관리를 요구합니다. 본 시스템은 이러한 글로벌 프레임워크를 금감원 AI RMF 및 인공지능기본법 요구사항과 통합하여, 모델 개발부터 폐기까지 일관된 관리 체계를 구축합니다.

MRM 생애주기

모델 리스크 관리는 5단계 생애주기를 따르며, 각 단계가 시스템 컴포넌트에 직접 매핑됩니다.

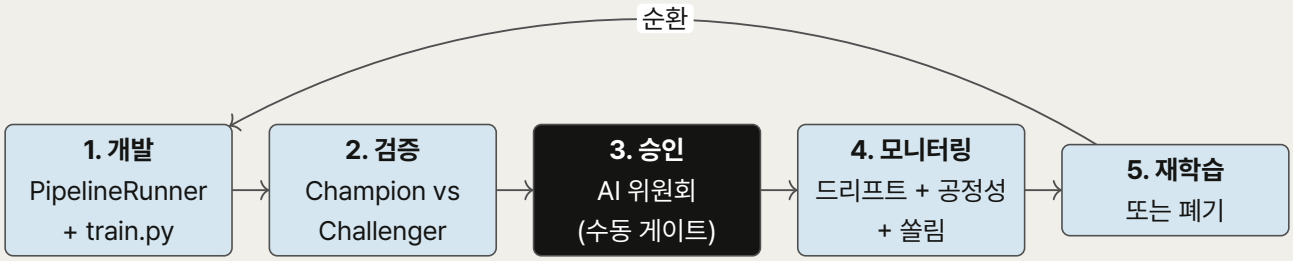

그림 6: MRM 생애주기: SR 11-7, NIST AI RMF, 금감원 AI RMF 기반 5단계 순환. 3단계(승인)는 반드시 수동.

단계	활동	시스템 컴포넌트	규제 근거
1. 개발	피처 파이프라인 구축, 모델 학습, 하이퍼파라미터 최적화	PipelineRunner + train.py + SageMaker Ablation	SR 11-7 Pillar 1
2. 검증	독립적 성능 평가, 공정성 감사, 편향 테스트	Champion-Challenger 비교 + FairnessMonitor	SR 11-7 Pillar 2
3. 승인	AI 위험관리위원회 심의, 배포 승인	ModelCompetitionManager (auto_promote=False)	NIST GOVERN
4. 모니터링	드리프트 감지, 성능 추적, 공정성 지표 측정	DriftDetector + PSI + DI/SPD/EOD	NIST MEASURE
5. 재학습/폐기	자동 재학습 트리거, 성능 미달 모델 폐기	ConsecutiveDriftTracker + dag_monthly_retrain	NIST MANAGE

모델 인벤토리

운영 중인 모든 모델을 추적하는 중앙 레지스트리를 유지합니다. SR 11-7은 조직 내 모든 모델의 목록화와 위험 등급 분류를 요구합니다.

모델 레지스트리 관리 항목

식별 정보: 모델 ID, 버전, 학습 일시, 학습 데이터 기간, 피처 스키마 해시
성능 기록: 태스크별 AUC/F1/MAPE, 검증 데이터셋 메트릭, calibration 지표
위험 등급: 고/중/저 3단계 (금감원 AI RMF 기준)
상태 관리: 개발중 → 검증중 → 승인 대기 → 운영중 → 폐기 (5단계 상태 전이)
감사 추적: 모든 상태 변경에 대한 변경자, 사유, 타임스탬프 기록

독립적 검증 (Champion-Challenger)

SR 11-7 Pillar 2가 요구하는 **독립적 모델 검증**을 Champion-Challenger 프레임워크로 구현합니다. 핵심 원칙은 모델 개발자가 아닌 독립적 프로세스가 승인 여부를 결정하는 것입니다.

자동 비교 기준

성능: 태스크별 AUC 동등 또는 우위
보정: Expected Calibration Error < 5%
공정성: DI/SPD/EOD 악화 없음
안정성: 검증 데이터 3-fold 분산 허용 범위 내

승인 프로세스

auto_promote=False: 자동 배포 차단
비교 보고서: 성능/공정성/안정성 종합 리포트 자동 생성
위원회 심의: AI 운영팀 검토 → 위험관리위원회 승인
promote/reject: 수동 의사결정 후 상태 전이

지속적 모니터링과 재학습 트리거

배포 후 모니터링은 세 가지 축으로 운영되며, 임계값 위반 시 자동 재학습 파이프라인이 작동합니다.

드리프트 감지 → 재학습

DriftDetector (PSI): 피처/예측/라벨 분포 변화를 일간 측정
ConsecutiveDriftTracker: PSI 임계값 초과가 **3일 연속** 발생 시 재학습 트리거 발동
재학습 파이프라인: dag_monthly_retrain → 신규 모델 학습 → dag_champion_challenger → 성능 비교 → 수동 승인

공정성 모니터링

FairnessMonitor: 보호 속성 5종(연령, 성별, 지역, 소득, 생애주기)에 대해 DI/SPD/EOD를 일간 측정
임계값 위반 시: 즉시 알림 발송 + 인시던트 기록 + 거버넌스 보고서에 자동 포함
연속 위반 시: 해당 세그먼트 추천 일시 중단 검토 (AI 운영팀 판단)

비상 대응 (Kill Switch)

모델이 예기치 않은 위험을 발생시킬 경우, 3단계 긴급 차단 메커니즘을 통해 즉시 대응합니다.

단계	조치	트리거 조건
1단계: 모델 비활성화	문제 모델의 서빙 즉시 중단	성능 위험(Red) 또는 공정성 임계값 중대 위반
2단계: 이전 버전 롤백	모델 레지스트리에서 직전 승인 버전으로 자동 복원	비활성화 후 자동 실행
3단계: 규칙 기반 폴백	AI 모델 전체 비활성화, 사전 정의된 규칙 기반 추천으로 전환	롤백 모델도 기준 미달 시

복구 절차: 원인 분석 → 수정 모델 학습 → Champion-Challenger 검증 → 위원회 승인 → 재배포. 모든 비상 대응 이력은 감사 로그에 불변 기록되며, 금감원 보고 대상 여부가 자동 판정됩니다.

운영 및 감사 에이전트

아키텍처 개요

서빙 에이전트(L1 Rule/L2a Retrieval/L2b Generation)는 실시간 추천 경로에 위치하며, 여기서 다루는 **OpsAgent**와 **AuditAgent**는 완전히 분리된 **배치 전용** 에이전트입니다. 서빙 경로와 상태를 공유하지 않으며, Airflow DAG의 후속 태스크로만 실행됩니다. 이 분리는 실시간 서빙 SLA에 영향을 주지 않으면서 규제 감시 기능을 수행하기 위한 설계 원칙입니다.

OpsAgent (운영 에이전트)

> **트리거 및 입력**
>
> **트리거**: `dag_drift_monitoring` 완료, 학습 Job 완료 이벤트
> **입력 데이터**:
> — `eval_metrics.json`: 태스크별 AUC/F1/MAPE, calibration 지표
> — 학습 로그: 태스크별 loss 추이, gradient norm 이력
> — Gate entropy: 전문가 라우팅 편중도 (MoE gate softmax 분포)
> — PSI 드리프트 보고서: 피처/예측/라벨 분포 변화

처리 파이프라인: JSON 파싱 → 이상 탐지 규칙 적용(임계값 기반 사전 필터링) → 이상 감지 시 LLM에 구조화된 프롬프트 전달.

> **프롬프트 예시**
>
> "다음 eval_metrics.json과 gate entropy를 분석하여 (1) 성능 저하 태스크 식별, (2) gate 편중 여부(entropy < 0.3인 전문가), (3) PSI 임계값 초과 피처 목록, (4) 권장 조치를 구조화하여 보고하시오."

출력: 모델 건강 보고서(Markdown) — S3 `governance/ops_reports/` 경로에 저장. 이상 감지 시 Slack 채널 및 이메일로 알림 발송.

AuditAgent (감사 에이전트)

> **트리거 및 입력**
>
> **트리거**: `dag_fairness_monitoring` 완료, 분기별 거버넌스 사이클(`dag_governance_quarterly`)
> **입력 데이터**:
> — FairnessMonitor 보고서: DI/SPD/EOD (보호 속성 5종 × 태스크별)
> — 감사추적 무결성 검증 결과: HMAC 해시 체인 검증 상태
> — 옵트아웃 통계: 기간별 요청 건수, 처리율, 평균 처리 시간
> — 거버넌스 체크리스트: 36항목 자동 점검 결과

처리 파이프라인: 규제 기준 대비 자동 비교(DI≥ 0.8, |SPD| ≤ 0.1, |EOD| ≤ 0.1) → 위반 항목 추출 → LLM에 위반 사항 요약 및 권장 조치 요청.

> **프롬프트 예시**
>
> "다음 공정성 지표를 금감원 기준(DI≥ 0.8, |SPD|≤ 0.1, |EOD|≤ 0.1)과 비교하여 (1) 위반 항목(보호 속성, 태스크, 지표값), (2) 위반 심각도(P1/P2/P3), (3) 권장 조치를 보고하시오."

출력: 규제 준수 보고서(Markdown) — S3 `governance/audit_reports/` 경로에 저장. 위반 감지 시 우선순위별 알림 발송: P1(즉시 에스컬레이션), P2(24시간 내 검토), P3(분기 보고서 포함).

모델 선택

환경	모델	사유
폐쇄망 (온프렘)	Exaone 3.5 7.8B (사유 생성) + Qwen 2.5 14B Q4 (에이전트 합의)	Apache 2.0 오픈소스. RTX 4070에서 순차 로딩.
클라우드 (AWS)	Claude Haiku 4.5 API	비용 효율적 ($0.25/1M input), 구조화된 출력 안정적

비용 추정: 배치당 1–2회 호출로 일일 비용 약 $0.01 이하. 입력은 JSON 메트릭(수 KB) + 프롬프트이므로 토큰 소모가 최소입니다.

설계 원칙

자동화 범위

배치 전용: 실시간 서빙 경로에 개입하지 않음
정형적 판단: 임계값 비교, 추세 분석, 위반 분류는 에이전트가 수행
비정형적 판단: 데이터 오염 의심, 비즈니스 맥락 변화, 규제 해석은 인간이 수행

감사 산출물 보장

HMAC 서명: 에이전트 출력 자체가 감사 산출물 — 생성 즉시 HMAC 서명 후 불변 저장
해시 체인: 이전 보고서와 연결된 해시 체인으로 변조 불가 보장
인간 검토: "출근 시 확인" 방식 — 에이전트가 정리하고 인간이 자기 페이스로 검토

Airflow DAG 통합

DAG	에이전트 태스크	실행 주기
`dag_drift_monitoring`	드리프트 감지 완료 후 → `ops_agent_report` 태스크 추가	일간
`dag_fairness_monitoring`	공정성 측정 완료 후 → `audit_agent_report` 태스크 추가	일간
`dag_governance_quarterly`	36항목 점검 완료 후 → `audit_agent_quarterly` 분기 보고서	분기
학습 Job 완료 콜백	`ops_agent_training_report` — 학습 메트릭 분석	이벤트

거버넌스 보고서 자동 생성

보고서 체계

월/분기 단위로 자동 생성되어 S3에 저장되고, AI 거버넌스 위원회에 배포됩니다.

9개 섹션 구성

섹션	내용	데이터 소스
1	공정성 요약 (DI/SPD/EOD by 보호 속성)	FairnessMonitor
2	드리프트 요약 (기간 내 PSI 통계)	DriftDetector
3	인시던트 요약 (CRITICAL/MAJOR/MINOR 건수 + 상세)	IncidentReporter
4	모델 변경 이력 (학습/배포/롤백)	ExperimentTracker
5	킬스위치 이력 (활성화/비활성화 횟수)	ComplianceAuditStore
6	추천 품질 (L1/L2 사유 품질 지표)	ReasonQualityMonitor
7	리스크 변동 (쏠림 추이, 리스크 수준)	HerdingDetector
8	감사 스토어 요약 (7개 테이블 건수)	ComplianceAuditStore
9	경영진 요약 (자동 생성 서술형)	종합

36항목 규제 준수 자동 점검

36항목 규제 준수 레지스트리를 통해 분기별 전체 점검이 자동 실행됩니다.

A그룹 (구현 완료 18항목)

모델 카드 · 학습 데이터 문서화 · 안전신뢰문서
AI 공시 · 설명 가능성 · 옵트아웃 권리
인간 검토 · 킬스위치 · 모델 롤백
헬스 체크 · 공정성 모니터링 · 적합성 제약 등

GAP그룹 (갭 분석 18항목)

드리프트 자동 대응 · 추천 사유 품질 검증
SLA 추적 · EU AI Act 고위험 분류
PIA (개인정보 영향 평가) 등

점검 주기:

- 일간: 킬스위치 상태, 헬스 체크
- 주간: 공정성 지표, 설명 가능성
- 분기: 전체 36항목 종합 점검

거버넌스 3계층 체계

1계층: 의사결정 – AI 위험관리위원회

AI 활용 정책 승인 · 고영향 AI 해당 여부 판단 · 연간 영향평가 승인 · 중대 사고 보고 체계

2계층: 실행 – AI 운영팀

모델 개발·운영 · 성과 모니터링 · 공정성 점검 · 추천 품질 관리 · 인시던트 대응

3계층: 검증 – 내부 감사·컴플라이언스

독립적 감사 · 규제 준수 확인 · 영향평가 검토 · 외부 감사 대응

적용 규제 종합 매핑

규제	관련 조항	설계 반영
AI 기본법	§31 (AI 생성물 표시)	AI 공시 + 추천 사유 L1/L2
	§33 (고영향 AI 거버넌스)	36항목 레지스트리 + 거버넌스 보고서
	§34 (위험 관리 기록)	감사 로그 불변성 + 7개 감사 테이블
금소법	§19 (설명의무)	피처 역매핑 + 태스크별 해석
금감원 AI RMF	①합법성	36항목 자동 점검
	②안전·신뢰	킬스위치 + 인시던트 보고
	④신뢰성	드리프트 감시 + 자동 재학습
	⑤금융안정성	공정성 DI/SPD/EOD + 쏠림 탐지
GDPR	§17 (삭제권)	30일 PII 보존 + 암호화 삭제
	§22 (자동화 거부)	opt_out_audit 테이블
	§35 (DPIA)	PIA 갭 분석 항목
개보법	§28의2 (가명정보)	가명 처리 기록 감사
	§37조의2 (자동화 결정)	옵트아웃 + 인적 재처리
EU AI Act	Art. 13 (투명성)	추천 사유 + 모델 카드 + 감사 로그
	Art. 14 (인간 감독)	킬스위치 + 인적 재처리 + 채널별 인간 감독
	Art. 15 (정확성·보안)	드리프트 감지 + 프롬프트 인젝션 방어

운영/감사 에이전트 통합

본 문서의 모든 규제 준수 컴포넌트(FairnessMonitor, HerdingDetector, ComplianceChecker, AuditLogger 등)는 AuditAgent의 도구(tool)로 래핑되어 48개 체크리스트 항목으로 자동 점검된다.

3-에이전트 합의 메커니즘(Sonnet×3 독립 투표)이 할루시네이션을 구조적으로 완화하며, 마이너리티 리포트가 소수 의견을 보존한다. 진단 이력은 LanceDB 케이스 스토어에 축적되어 규제기관 감사 시 "지속적 개선 증명" 근거로 활용된다.

핵심 설계 원칙: **"AI가 분석하고, 사람이 판단한다"** — 에이전트는 권고만 하고 최종 의사결정은 담당자가 수행. EU AI Act Art.14(인간 감독), 금감원 AI 가이드라인(인간 개입), AI 기본법(킬스위치)을 구조적으로 충족.

상세 설계: Design Document 11 (`docs/design/11_ops_audit_agent.typ`)

시간적 팩트 스토어 (2026-04 추가)

감사 증적의 핵심 요구사항 중 하나는 **"특정 시점의 시스템 상태 복원"**이다. "2026-03-15에 고객 A에게 추천한 시점의 모델 버전, 피처, 판정은 무엇이었는가?" 같은 질문에 답하려면 분산된 여러 컴포넌트(AuditLogger, DiagnosticCaseStore, `pipeline_state.json`)를 조인해야 하는데 비용이 크다.

이 문제를 Zep/Graphiti 패턴에서 차용한 `TemporalFactStore`로 해결했다. 스키마는 `(entity, attribute, value, valid_from, valid_to)`이며, 대부분의 감사 질의가 **단일 엔티티의 시점 복원**이라 LanceDB 네이티브 필터로 해결된다.

특성	구현
삭제 불가	`expire_fact()`는 `valid_to`만 설정, 원본 보존
백엔드	`DiagnosticCaseStore`와 LanceDB 인스턴스 공유 (신규 의존성 0)
Z-suffix 호환	외부 캘러의 다양한 timestamp 형식 정규화
쿼리 API	`snapshot_at()`, `get_timeline()`, `expire_fact()`

이 설계는 EU AI Act 제12조(기록 보관), 금감원 AI 가이드라인(감사 추적), AI 기본법의 시계열 증적 요구사항에 부합하도록 설계된 단일 스토어 구조이다.

본 문서는 2026년 4월 기준으로 작성되었으며, 인공지능기본법 시행령 및 금융위원회 통합 AI 가이드라인의 확정·시행에 따라 내용이 변경될 수 있습니다. 규제 환경 변화 시 문서를 갱신하고,
AI 위험관리위원회에 보고하는 절차를 권고합니다.